

Threat Model

Scope

AMW Command manages performance evaluations, comments, scores, salary summaries, and acknowledgements. The highest-risk assets are HR records, salary and bonus data, authentication tokens, and audit trails.

Primary Actors

- Employee: can view and sign their own assigned evaluations.
- Manager: can evaluate assigned employees, create cycles, view reports, and export management-scoped records.
- Admin: can manage users, templates, cycles, reports, and all evaluations.
- External attacker: unauthenticated party attempting credential abuse, data extraction, or service disruption.

Key Threats And Controls

Threat	Risk	Current Controls	Next Hardening
Credential stuffing	Unauthorized access	Auth rate limiter, company email validation	SSO/MFA, account lockout policy
Token theft	Account takeover	Session storage, short request timeout	HttpOnly cookies, refresh token rotation
Broken access control	HR data leak	RBAC middleware, evaluation access checks, integration tests	Route-level authorization matrix reviews
Sensitive export leakage	Salary data leak	Export role filtering	Server-side PDF generation and export audit sink
XSS	Token/data theft	React escaping, CSP baseline	Strict CSP tuning, security review of rich text
Dependency compromise	Supply chain risk	npm audit, Dependabot	SBOM generation, signed artifacts
Secret leakage	Environment compromise	Gitleaks in CI	Repository-wide historical scan and rotation
Production outage	Business interruption	Readiness endpoint, graceful shutdown	HA deployment, rollback automation

Residual Risk

The current bearer-token browser model remains acceptable for internal controlled use, but a high-value production deployment should move to SSO or HttpOnly cookie sessions with refresh rotation and MFA.

Review Cadence

- Review this model before each major release.
- Re-run RBAC and export tests after every route or role change.
- Revisit salary/export controls whenever reporting requirements change.